

Checklist: Proyecto 3 - Hardening y Seguridad (2025-II)

1. HTTPS/TLS (Comunicación Segura)

Requisito: Todos los servicios expuestos DEBEN usar HTTPS.

- ☐ **Configuración General:**
 - ☐ Asegurar que el Frontend sea accesible únicamente por HTTPS
 - ☐ Configurar certificado TLS en el API Gateway
 - ☐ Implementar redirección automática HTTP → HTTPS
 - ☐ Configurar Headers de seguridad (HSTS, X-Frame-Options, CSP, etc.)
- ☐ **Implementación (Elegir una):**
 - ☐ Opción A: Traefik con gestión automática (Recomendado)
 - ☐ Opción B: Certificados autofirmados con OpenSSL
 - ☐ Opción C: Let's Encrypt con Certbot
- ☐ **Entregables:**
 - ☐ Script de generación de certificados en `scripts/security/`
 - ☐ Captura de pantalla del navegador mostrando el candado/HTTPS activo
 - ☐ Documentación del proceso en el `README`

2. Hardening de Contenedores Docker

Requisito: Aplicar mejores prácticas de seguridad en imágenes y ejecución.

- ☐ **Dockerfiles:**
 - ☐ Configurar usuario no privilegiado (no usar root)
 - ☐ Usar versiones específicas en imágenes base (NO usar tag `:latest`)
 - ☐ Implementar Multi-stage builds (separar construcción de ejecución)
- ☐ **Docker Compose:**
 - ☐ Configurar `security_opt: no-new-privileges`
 - ☐ Eliminar capabilities innecesarias (`cap_drop`)
 - ☐ Definir límites de recursos (CPU y Memoria)
 - ☐ Configurar políticas de reinicio (`restart policies`)
 - ☐ Configurar rotación de logs
- ☐ **Entregables:**
 - ☐ Reporte de escaneo de vulnerabilidades (Trivy, Docker Scout, etc.)
 - ☐ Documento explicativo: `docs/hardening-contenedores.md`

3. Hardening de Bases de Datos

Requisito: Asegurar el motor de BD según mejores prácticas.

- ☐ **Autenticación y Usuarios:**
 - ☐ Deshabilitar acceso sin contraseña y acceso remoto de root
 - ☐ Configurar contraseñas fuertes (mínimo 12 caracteres)

- ☐ Crear usuario específico para la aplicación con privilegios mínimos (SELECT, INSERT, UPDATE, DELETE)
- ☐ Revocar permisos administrativos al usuario de la aplicación (DROP, GRANT, etc.)
- ☐ **Red y Configuración:**
 - ☐ Aislar la BD en una red interna de Docker
 - ☐ **NO** exponer puertos de la BD al host (solo acceso interno)
 - ☐ Habilitar logs de conexiones, desconexiones e intentos fallidos
- ☐ **Entregables:**
 - ☐ Archivos de configuración en `infrastructure/database/`
 - ☐ Scripts de inicialización de usuarios y permisos
 - ☐ Documento explicativo: `docs/hardening-database.md`
 - ☐ Evidencia (captura/log) de que la BD no es accesible desde el host.

4. Gestión de Secretos

Requisito: Cero credenciales en texto plano en el código o repositorio.

- ☐ **Implementación:**
 - ☐ Usar Docker Secrets (Recomendado) o variables de entorno seguras.
 - ☐ Asegurar que el archivo `.env` esté en `.gitignore`.
 - ☐ Crear archivo plantilla `.env.example`.
- ☐ **Operación:**
 - ☐ Implementar mecanismo de rotación de secretos.
 - ☐ Verificar que no existan secretos en el historial de Git.
- ☐ **Entregables:**
 - ☐ Script de rotación en `scripts/security/rotate-secrets.sh`.
 - ☐ Documentación de uso en el `README`.

5. WAF / Rate Limiting

Requisito: Protección básica contra ataques web.

- ☐ **Configuración (Traefik, Nginx o ModSecurity):**
 - ☐ Implementar Rate Limiting (límite de peticiones por IP).
 - ☐ Bloquear User-Agents maliciosos conocidos.
 - ☐ Configurar headers de seguridad HTTP.
 - ☐ Habilitar logs de peticiones bloqueadas.
- ☐ **Entregables:**
 - ☐ Logs que demuestren bloqueos efectivos.
 - ☐ Capturas de pantalla de pruebas de bloqueo.

6. Análisis de Vulnerabilidades

Requisito: Escanear y documentar fallos.

- ☐ **Ejecutar Escaneos:**
 - ☐ Imágenes Docker (Trivy, Docker Scout o Anchore).
 - ☐ Dependencias de código (`npm audit` o `pip safety`).
 - ☐ Puertos abiertos (`nmap`).

- ☐ Análisis web básico (Nikto o similar).
- ☐ **Entregables:**
 - ☐ Script automatizado: `scripts/security/scan-vulnerabilities.sh`.
 - ☐ Carpeta con reportes: `docs/reportes/`.
 - ☐ Documento de remediación: `vulnerabilidades-remediadas.md` (Qué se arregló y qué se aceptó con justificación).

7. Logging y Auditoría de Seguridad

Requisito: Sistema centralizado enfocado en seguridad.

- ☐ **Configuración:**
 - ☐ Implementar sistema (Loki+Grafana recomendado o Docker logs básico)
 - ☐ Registrar eventos obligatorios: Autenticación (éxito/fallo), Accesos denegados (401/403), Acceso a endpoints sensibles, Cambios de config, Conexiones a BD
- ☐ **Entregables:**
 - ☐ Configuración de logs en `docker-compose.yml`.
 - ☐ Script para consultar logs de seguridad.
 - ☐ Dashboard o capturas mostrando los logs funcionando.

8. Documentación y Políticas (Carpeta `docs/`)

Requisito: 5 documentos obligatorios en Markdown (mínimo 1-2 páginas c/u).

- ☐ `docs/politica-seguridad.md`: Objetivos, responsabilidades, contraseñas, actualizaciones, accesos, logs.
- ☐ `docs/matriz-riesgos.md`: 8-10 riesgos principales (Probabilidad/Impacto/Mitigación).
- ☐ `docs/owasp-top10.md`: Checklist de los 10 riesgos OWASP y su mitigación en el proyecto.
- ☐ `docs/plan-incidentes.md`: Detección, contención, análisis, recuperación y lecciones aprendidas.
- ☐ `docs/cumplimiento-normativo.md`: Ley 19.628, Ley 21.459, Normas Gobierno Digital.